

ADVANCED FINANCIAL SECTOR THREAT HUNTING

Network Telemetry & SIEM Detection Engineering
Enterprise Architecture (50-Page Scope)

Disusun Oleh: **Rizki Angga Pratama**
L2 SOC Analyst

HAK CIPTA & DISCLAIMER

Advanced Financial Sector Threat Hunting & Network Telemetry
Edisi Enterprise (50 Halaman Arsitektural)

Dokumen ini ditujukan secara eksklusif bagi Arsitek Keamanan Perusahaan, Analis SOC Level 3, dan Pemburu Ancaman (Threat Hunters) yang beroperasi di sektor perbankan dan infrastruktur finansial kritis.

> **Peringatan Lingkungan Operasional:**
> Eksplorasi dan penguraian protokol finansial secara *real-time* di lingkungan produksi memerlukan otorisasi eksekutif. Menerapkan *Deep Packet Inspection* (DPI) secara sembrono pada *Payment Switch* dapat menyebabkan *latency* yang melanggar SLA Transaksi Finansial.

© 2026 Hak cipta dilindungi undang-undang. Panduan Infrastruktur Kritis Finansial Nasional.

KATA PENGANTAR

Sejarah peretasan finansial telah berevolusi jauh melampaui pencurian basis data nasabah biasa. Ketika kelompok APT kelas negara seperti Lazarus Group atau sindikat kriminal FIN7 meretas sebuah bank, mereka tidak mencari data kartu kredit; mereka meretas infrastruktur tulang punggung bank itu sendiri.

Mereka menembus jaringan SWIFT untuk mentransfer miliaran dolar melintasi batas negara, dan mereka menyusupi *Payment Switch* untuk memerintahkan ribuan mesin ATM memuntahkan uang tunai secara serentak (Jackpotting). Untuk menghentikan ancaman tingkat lanjut ini, Analis SOC tidak bisa lagi hanya mengandalkan peringatan Antivirus atau *Firewall* tradisional.

Buku ini merupakan cetak biru metodologis untuk membangun arsitektur pemantauan tanpa celah. Melalui instrumen seperti Zeek, Suricata, dan integrasi ELK/Splunk tingkat lanjut, kita akan membangun jaring deteksi yang mutlak.

— Rizki Angga Pratama

DAFTAR ISI (1/2)

BAGIAN I: Anatomi Permukaan Serangan Finansial

- Bab 1.1 Ekosistem Jaringan SWIFT (SAA, SAG, SNL) ..... Hlm. 7
- Bab 1.2 Protokol ISO 8583 & Kerentanan Payment Switch ..... Hlm. 8
- Bab 1.3 Eksploitasi Core Banking (AS/400 & Mainframes) ..... Hlm. 9
- Bab 1.4 ATM Logical Attacks (Jackpotting & Black Box) ..... Hlm. 10
- Bab 1.5 HSM (Hardware Security Module) Bypass ..... Hlm. 11

BAGIAN II: Network Telemetry & Visibilitas Lanjut

- Bab 2.1 Deep Packet Inspection (DPI) menggunakan Zeek ..... Hlm. 13
- Bab 2.2 Dekripsi SSL/TLS Terpusat di Zona Finansial ..... Hlm. 14
- Bab 2.3 Deteksi Anomali PCAP pada Pesan SWIFT ..... Hlm. 15
- Bab 2.4 NetFlow/IPFIX untuk Analisis Lateral Movement ..... Hlm. 16
- Bab 2.5 BGP Hijacking & Rute Transaksi Finansial ..... Hlm. 17

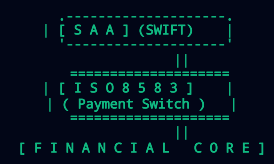
DAFTAR ISI (2/2)

BAGIAN III: Emulasi Ancaman (APT TTPs) di Sektor Bank

- Bab 3.1 Lazarus Group: Anatomi Serangan FASTCash ..... Hlm. 19
- Bab 3.2 FIN7 / Carbanak: Manipulasi Database ..... Hlm. 20
- Bab 3.3 Living off the Land (LotL) di Lingkungan Bank ..... Hlm. 21
- Bab 3.4 Manipulasi Kredensial (Kerberoasting) ..... Hlm. 22
- Bab 3.5 Serangan Rantai Pasok Finansial ..... Hlm. 23

BAGIAN IV hingga VII: SIEM Engineering, IR, & AI Threats

- Bagian IV: SIEM Detection Engineering & Data Lake (Bab 4.1-4.5) ... Hlm. 25-29
- Bagian V: Respons Insiden Jaringan Kritis (Bab 5.1-5.5) ..... Hlm. 31-35
- Bagian VI: Mainframe Forensics & AS/400 Auditing (Bab 6.1-6.5) ... Hlm. 37-41
- Bagian VII: Adversarial AI & Deepfake Threats (Bab 7.1-7.4) ..... Hlm. 43-46
- Referensi Jurnal & Glosarium Keamanan Finansial ..... Hlm. 47-49
- Back Cover (The Financial Cyber Architect) ..... Hlm. 50



BAGIAN I

Anatomi Permukaan Serangan Finansial (Eksploitasi Infrastruktur Kritis)

BAB 1: INFRASTRUKTUR PEMBAYARAN

1.1 Ekosistem Jaringan SWIFT (SAA, SAG, SNL)

SWIFT bukanlah sistem transfer uang; ia adalah *Messaging System* ultra-aman yang memberitahu bank untuk memindahkan uang. Arsitektur lokal sebuah Bank yang terhubung ke SWIFT terdiri dari: **CBA (Core Banking Application)**, **SAA (SWIFT Alliance Access)**, dan **SAG (SWIFT Alliance Gateway)**.

Penyerang APT tidak menyerang jaringan global SWIFT (yang dilindungi HSM tingkat militer). Penyerang meretas jaringan LAN kantor bank, melakukan eskalasi ke server SAA, lalu menyuntikkan (*Inject*) pesan MT103 palsu yang terlihat sah karena berasal dari server otorisasi bank itu sendiri.

1.2 Protokol ISO 8583 & Kerentanan Payment Switch

Transaksi ATM harian Anda menggunakan protokol biner warisan **ISO 8583**. Format ini bergantung pada *Data Elements (DE)*. Contohnya `DE-2` (Nomor Kartu), `DE-4` (Jumlah Transaksi), dan `DE-39` (Kode Respons).

Jika pemburu ancaman tidak memantau port mentah Switch (Port 10000+), peretas dapat mencegat pesan transit (*Man-in-the-Middle*). Peretas mengubah `DE-39` dari "Saldo Kosong" (51) menjadi "Disetujui" (00) secara *on-the-fly*, memaksa ATM mengeluarkan uang tanpa izin Core Banking.

1.3 Eksploitasi Core Banking (AS/400 & Mainframes)

Jantung perbankan Tier-1 masih berjalan di IBM iSeries (AS/400) atau Z/OS Mainframes menggunakan bahasa COBOL. Sistem ini kebal *Malware* .exe Windows, namun sangat rentan terhadap serangan Kredensial (*Lateral Movement*).

APT mengkompromikan PC Administrator, mencuri makro sesi emulator terminal (TN3270), lalu memanipulasi *Job Control Language (JCL)* untuk menyuntikkan saldo palsu langsung ke tabel basis data DB2, melangkahi seluruh validasi aplikasi antarmuka pengguna.

1.4 ATM Logical Attacks (Jackpotting & Black Box)

Mesin ATM modern adalah komputer Windows 10 IoT yang memfasilitasi brankas perangkat keras via *Middleware* **XFS (Extensions for Financial Services)**.

Dalam *Black Box Attack*, penyerang melubangi *casing*, memotong kabel USB penghubung Dispenser, dan menyambungkannya ke Raspberry Pi eksternal. Mereka mengirimkan `WFSExecute(WFS_CMD_CDM_DISPENSE)` langsung ke perangkat keras uang tunai, melewati seluruh otentikasi jaringan bank.

1.5 HSM (Hardware Security Module) Bypass

Setiap transaksi finansial PIN dienkripsi menggunakan HSM fisik (seperti Thales payShield). HSM dirancang anti-bobol (*Anti-Tamper*).

Namun, peretas tidak menyerang HSM-nya. Mereka mengeksploitasi **HSM API Layer**. Jika peretas mendapatkan akses ke peladen Payment Switch, mereka memanggil perintah *API Generate/Verify PIN* secara sewenang-wenang. Mereka memanfaatkan fitur *PIN Translation* untuk mendekripsi PIN blok nasabah secara *Cleartext* ke memori peladen, menyalahgunakan fungsi HSM sah untuk tujuan jahat.



BAGIAN II

Network Telemetry & Visibilitas Lanjut
(Deep Packet Inspection)

BAB 2: PEMANTAUAN JARINGAN BANK

2.1 Deep Packet Inspection (DPI) menggunakan Zeek

IDS tradisional buta terhadap protokol perbankan. SOC menggunakan **Zeek** untuk analisis semantik jaringan. Zeek mengubah lalu lintas jaringan mentah menjadi log JSON terstruktur.

```
# Zeek Script (ISO 8583 Recon Anomaly) if ( mti == "0800" ) { if ( c$id$orig_h in watchlist_ips ) { NOTICE([$note=ISO8583_Recon_Anomaly, $msg="Potential Switch Recon"]); } }
```

Skrip Zeek mendeteksi jika ada pesan "Network Management" (0800) yang dikirim berturut-turut tanpa transaksi valid, mengindikasikan upaya *Reconnaissance* peretas.

2.2 Dekripsi SSL/TLS Terpusat

Hampir 100% *Malware* mengenkripsi komunikasinya. Pusat Data Perbankan mengatasi *Blind Spot* ini dengan **SSL Decryption Zones (Break and Inspect)**.

Next-Generation Firewall bertindak sebagai proksi transparan. Ia mencegat komunikasi, membongkarnya menjadi *Cleartext*, lalu menyalin data (Port Mirroring) ke sensor Zeek/Suricata, sebelum dienkripsi ulang (*Re-encrypt*). Ini memungkinkan visibilitas absolut di zona Core tanpa melanggar kepatuhan enkripsi lalu lintas eksternal.

2.3 Deteksi Anomali PCAP pada Pesan SWIFT

Menangkap paket *Full Packet Capture (PCAP)* di sekitar Switch SAA memungkinkan forensik presisi. Peretas sering menggunakan taktik *Message Tampering* pada format MT103 dan MT202.

Threat Hunters mengotomatisasi ekstraksi *Payload* Tag 32A (Jumlah Uang). Jika ML Baseline mendeteksi transfer devisa yang melonjak dari rata-rata historis $10K menjadi $10 Juta di luar jam operasional kliring, SOAR *Playbook* secara otonom mematikan port *Switch* jaringan tersebut secara instan.

2.4 NetFlow & IPFIX untuk Analisis Lateral

Menyimpan PCAP untuk berbulan-bulan terlalu mahal (Petabytes). SOC beralih ke **NetFlow/IPFIX**, yang hanya menyimpan *Metadata* koneksi (Siapa berbicara dengan siapa, kapan, dan durasinya).

NetFlow mendeteksi *Lateral Movement*. Jika peladen mesin cetak (*Print Server*) tiba-tiba mencoba membuka koneksi SMB (Port 445) ke ratusan PC *Teller* dalam 1 menit, grafik NetFlow akan menampilkan lonjakan (*Spike*) tajam, membuktikan adanya penyebaran *Ransomware* internal aktif.

2.5 BGP Hijacking & Rute Transaksi Finansial

Ancaman infrastruktur tingkat tinggi adalah **BGP (Border Gateway Protocol) Hijacking**. Intelijen asing mengumumkan rute AS (Autonomous System) palsu ke jaringan internet global, menyedot (*Blackholing* atau *Intercepting*) lalu lintas transaksi bank internasional Anda ke negara mereka.

Telemetri SOC harus mengintegrasikan *BGP Route Monitoring* global. Jika alamat IP perbankan secara anomali dirutekan melalui ISP di Rusia atau Tiongkok selama 3 menit (sebelum dikembalikan), ini adalah operasi penyadapan tingkat negara (*State-Sponsored Traffic Interception*).



BAGIAN III

Emulasi Ancaman (APT TTPs)
(Menghadapi Kartel Siber Finansial)

BAB 3: TAKTIK & PROSEDUR (TTPS)

3.1 Lazarus Group: Serangan FASTCash

Sindikat Korea Utara (Lazarus APT) meretas peladen *Payment Switch Middleware* bank secara internal, lalu menanamkan *AIX/Linux Rootkit* siluman.

Ketika komplotan *Mule* (Kurir Uang) mereka di luar negeri menarik uang dari kartu yang bersaldo kosong, *Rootkit* mencegat pesan ISO 8583. Ia secara palsu merespons Kode 00 (Sukses) kembali ke mesin ATM, tanpa pernah mengabari sistem Core Banking. Puluhan juta dolar terkuras tanpa alarm internal yang menyala.

3.2 FIN7 / Carbanak: Manipulasi Database

Grup FIN7 menargetkan staf bank dengan **Spearphishing Word Macro**. Setelah mendapatkan akses (*Initial Shell*), mereka melakukan pengintaian pasif (Dwell Time) berbulan-bulan, merekam layar untuk mempelajari alur persetujuan transaksi (*Approval Workflow*).

Mereka kemudian melewati aplikasi GUI bank, mengakses langsung *Database SQL*, lalu menggelembungkan saldo rekening komplotan mereka di buku besar, yang kemudian dicairkan dengan mulus via RTGS kliring.

3.3 Living off the Land (LotL) di Bank

Antivirus di peladen perbankan membunuh eksekusi *.exe* asing seketika. APT beradaptasi dengan **Living off the Land (LotL)**. Mereka HANYA menggunakan perangkat lunak sah (PowerShell, WMI, CertUtil).

Mereka meluncurkan *Fileless Malware* yang berjalan utuh di RAM melalui PowerShell terenkripsi (Base64). Karena bank sendiri menggunakan skrip PowerShell untuk tugas Admin rutin, EDR dibanjiri alarm *False Positive*, menyembunyikan serangan sungguhan di lautan aktivitas harian (Noise).

3.4 Manipulasi Kredensial (Kerberoasting)

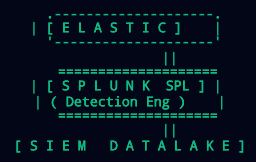
Seluruh sistem otentikasi bank diikat oleh Microsoft Active Directory (AD). Teknik eskalasi favorit adalah **Kerberoasting**. Penyerang meminta tiket Kerberos (TGS) untuk Akun Layanan Bank (*Service Accounts*).

Tiket ini dienkripsi menggunakan *Hash* kata sandi akun layanan tersebut. Penyerang mengambil tiket tersebut secara *offline* ke komputer mereka sendiri, dan melakukan *Brute-Force* kata sandinya (Hashcat). Jika berhasil, mereka mendapatkan hak Admin Domain yang tak tertandingi.

3.5 Serangan Rantai Pasok Finansial

Seringkali, meretas bank teramat sulit. APT menyerang vendor pihak ketiga (Vendor Perangkat Lunak Kliring Lokal) yang memasok pembaruan aplikasi ke bank tersebut. Mereka menyisipkan *Trojan* ke dalam *Update Patch* resmi vendor (Supply Chain Compromise).

Saat staf bank menginstal *Patch* resmi, *Malware* terkirim. Deteksi ancaman di sektor finansial harus memverifikasi integritas Tanda Tangan Kriptografis dari setiap artefak vendor sebelum didorong ke produksi (DevSecOps CI/CD).



BAGIAN IV

SIEM Detection Engineering &
Analitik Data Lake Skala Bank

BAB 4: KUERI SIEM LANJUT

4.1 Kueri Elastic KQL untuk Core Banking

Elastic Security menggunakan *Event Query Language (EQL)* untuk menemukan korelasi urutan (*Sequence Correlation*).

```
// EQL: Deteksi akses Ledger di luar jam, diikuti aktivitas PowerShell Network sequence by user.name with maxspan=15m [file where event.action == "access" and file.name : "*customer_ledger*.db"] [process where event.type == "start" and process.name == "powershell.exe" and process.command_line : "*Invoke-WebRequest*"]
```

Jika staf menyentuh berkas krusial dan dalam 15 menit PowerShell mencoba mengunduh *Payload* internet, peringatan *Insider Threat* / *Compromised Account* terpicu otomatis.

4.2 Splunk SPL: Memburu Golden Ticket

Peretas menggunakan **Golden Ticket** (Tiket Kerberos TGT yang dipalsukan) untuk bertahan abadi (*Persistence*) di jaringan Windows Bank. Kita mendeteksinya via SPL Splunk.

```
/* Splunk SPL: Anomali Lifetime Golden Ticket (> 10 Jam) */ index=windows_sec EventCode=4769 | eval TicketLifeTime = (TicketEndTime - TicketStartTime) | where TicketLifeTime > 36000 | stats count by TargetUserName, ClientAddress, TicketOptions
```

Kueri ini mencari tiket Kerberos yang masa berlakunya (*Lifetime*) melebihi batas kebijakan Domain bawaan Windows (10 Jam). Tiket anomali ini 100% adalah hasil tempaan alat *Mimikatz* peretas.

4.3 Sigma Rules: Deteksi Injeksi Memori

Sigma Rules adalah *Rosetta Stone* penulisan aturan SIEM (Format YAML agnostik). Banyak APT menggunakan *Cobalt Strike* melalui teknik *Process Hollowing*.

```
# Sigma: Suspicious Process Injection into Svchost selection: TargetImage|endswith: '\svchost.exe' SourceImage|endswith: '\powershell.exe' GrantedAccess: '0x1F0FFF' # PROCESS_ALL_ACCESS
```

Jika PowerShell meminta hak akses *ALL_ACCESS* kepada proses Sistem (svchost.exe), Sigma Rule ini dikonversi otomatis oleh SOAR menjadi Kueri QRadar/Splunk untuk memblokir teknik eksekusi *Beacon Cobalt Strike* seketika.

4.4 Konvergensi: Pertahanan Siber vs Deteksi Fraud

Secara tradisional, Tim Siber SOC dan Tim *Anti-Fraud* Kartu Kredit bank beroperasi terpisah (Silo). Di masa depan, **Konvergensi SIEM** adalah keharusan.

Jika peretas meretas Kredensial Database (Siber) dan menggelembungkan limit kartu kredit (Fraud), pemisahan tim akan membuat bank buta. *Unified Data Lake* mengkorelasikan log Windows Event (Cyber) dengan Log ISO 8583 (Fraud) dalam satu *Dashboard Entity Risk* untuk merangkai *Cyber-Enabled Fraud Attack* secara komprehensif.

4.5 Machine Learning Baselines untuk Anomali

Membuat aturan Statis (Threshold) di Perbankan sering kali gagal karena volume transaksi memuncak secara wajar di akhir bulan (Payday). SOC menggunakan **Machine Learning Anomaly Baselines**.

ML memonitor aktivitas (Misal: Volume Data Keluar / *Egress Traffic* per alamat IP) selama 30 hari untuk belajar profil "Kewajaran". Jika pada hari libur nasional sebuah peladen *Backup* mentransfer 500GB ke alamat IP Rusia, model *Unsupervised ML* mendeteksinya sebagai Kritis (Z-Score Deviation), meskipun 500GB adalah volume wajar di hari kerja biasa.



BAGIAN V

Respons Insiden Jaringan Kritis
(Zero-Downtime Containment)

BAB 5: FORENSIK & REMEDIASI BANK

5.1 Isolasi Jaringan Dinamis (Zero-Downtime)

Mencabut kabel server *Payment Switch* yang terkena *Malware* akan mematikan transaksi bank dan melanggar SLA Nasional. SOC Perbankan menggunakan **Zero-Downtime Micro-Segmentation**.

Menggunakan arsitektur SDN (Cisco ACI/NSX), sistem SOAR menyuntikkan kebijakan Firewall level-Hypervisor yang HANYA memblokir koneksi *Egress* (Keluar) ke Port anomali (Mematikan jalur C2 peretas), tetapi membiarkan port transaksi aplikasi sah (Misal Oracle TCP 1521) tetap berjalan normal. Infeksi dikarantina, namun operasional bisnis selamat.

5.2 Analisis Memori Payment Gateway

APT Finansial menggunakan *Fileless Malware* yang hidup murni di RAM. Tim IR mengoperasikan alat *Memory Dumping* (seperti LiME untuk Linux) untuk menyalin kondisi RAM peladen *Payment Gateway*.

Dalam *Volatility Framework*, analis memburu proses tersembunyi (*Rootkits*) yang menyadap panggilan sistem (*Syscall Hooking*). Mereka dapat menemukan kunci dekripsi *Hardcoded*, *Payload* peretasan, dan alamat IP Pusat Komando (C2) yang tergeletak telanjang di keping memori sebelum peladen dimatikan (*Reboot*).

5.3 Triase Log Windows Event Forwarding (WEF)

Bank memiliki puluhan ribu PC Cabang (Teller). Memasang agen pengirim log (*Log Shipper*) yang berat di setiap PC akan menghancurkan performanya. Bank menggunakan **Windows Event Forwarding (WEF)**.

WEF (Berbasis WinRM HTTPS) menarik (*Push/Pull Subscription*) log keamanan penting secara terpusat (*Event ID 4688 Process Creation, 4624 Logon*) melalui Kebijakan Grup (GPO) tanpa *overhead* agen eksternal, memberikan SOC mata pengawasan tak terbatas ke pelosok cabang daerah.

5.4 YARA Rules untuk Malware Mesin ATM

Mesin ATM rentan terhadap *Malware* spesifik (seperti Ploutus, Tyupkin). *Threat Hunters* mendistribusikan **YARA Rules** (Alat pengenalan pola memori dan biner) ke seluruh jaringan ATM Endpoints.

Aturan YARA ini secara konstan memindai memori operasi ATM untuk mencari *String Hexadecimal* yang secara eksklusif terkait dengan panggilan API `XFS_DISPENSE` peretas, atau *String* rahasia perintah aktivasi *Black Box*, menghancurkan *Malware* Jackpopping sebelum kas uang terbongkar.

5.5 SOAR Automated Response Playbooks

Kecepatan APT mengeksfiltrasi data dihitung dalam hitungan detik. **Security Orchestration, Automation, and Response (SOAR)** mengeksekusi *Playbook* mitigasi kecepatan-mesin.

Jika alarm *High-Fidelity* dari EDR atau Splunk terpicu, *Playbook* Python SOAR akan berjalan otonom: 1) Blokir IP di Palo Alto Firewall, 2) Karantina Host di CrowdStrike, 3) Nonaktifkan Akun AD Karyawan yang kredensialnya bocor, dan 4) Kirim pesan triase ke saluran Slack SOC. Waktu Respon Insiden (MTTR) merosot dari berjam-jam menjadi milidetik.



BAGIAN VI

Mainframe Forensics & AS/400 Auditing (Keamanan Core Banking)

BAB 6: ANALITIK MAINFRAME SIBER

6.1 Forensik Mainframe (z/OS)

Di saat para analis SOC fokus pada Linux dan Windows, celah buta (*Blind Spot*) terbesar Bank adalah peladen Mainframe Z/OS tempat milyaran uang berdiam. Arsitektur z/OS tidak menggunakan log teks tradisional, melainkan merekam semua kejadian sistem ke dalam berkas **SMF (System Management Facility)**.

Data SMF berformat biner eksotis. SIEM korporat memerlukan penerjemah perantara (Log Forwarder khusus) untuk mem-*parsing* SMF menjadi JSON agar Splunk dapat membaca anomali (seperti pelanggaran otentikasi TSO/ISPF atau modifikasi tabel dataset krusial) secara *real-time*.

6.2 AS/400 (IBM i) Auditing

Core Banking *Midrange* (IBM iSeries / AS/400) mencatat aktivitas di **QAUDJRN (Security Audit Journal)**. Entri log menggunakan kode Jurnal seperti `PW` (Perubahan Sandi) atau `AF` (Kegagalan Akses Otorisasi).

APT mengeksploitasi fitur perintah eksekusi jarak jauh (*Remote Command Execution* via koneksi ODBC/JDBC) untuk menjalankan skrip CLI (CL Commands) tanpa mengotentikasi antarmuka layar hijau 5250. Memantau QAUDJRN secara sentral untuk Kode Akses basis data tak wajar (`ZD` Database Access) mencegah injeksi modifikasi buku besar kliring.

6.3 RACF and ACF2 Exploitation

Manajemen Hak Akses Mainframe dijaga oleh **RACF, ACF2, atau Top Secret**. Peretas Mainframe elit tidak menjalankan *Malware*; mereka menyalahgunakan kerentanan hak (*Misconfigurations*) pada profil RACF (*Dataset Profiles*).

Jika *Dataset APF-Authorized* dikonfigurasi dengan izin `UACC(UPDATE)`, penyerang yang hanya memiliki hak staf *Teller* dapat menimpa Pustaka Sistem Inti (System Core Library), mengangkat status mereka menjadi `SPECIAL` (Superadmin Mainframe) secara instan, dan menghapus seluruh jejak Log SMF pembobolan mereka.

6.4 EBCDIC to ASCII Payload Conversion

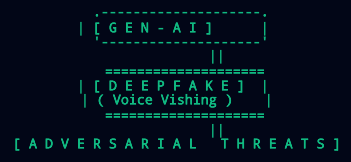
Tantangan Forensik Siber di Mainframe adalah perbedaan Pengkodean Teks. Internet dan SIEM menggunakan ASCII/UTF-8, sedangkan Mainframe menggunakan format warisan IBM: **EBCDIC**.

Jika peretas mengunggah *Shellcode Malware* (atau skrip peretasan) dari internet ke Mainframe, lapisan FTP/SSH akan secara otomatis menerjemahkan ASCII ke EBCDIC, merusak struktur biner *Payload*. Penyerang tingkat lanjut merancang *Alphanumeric Shellcode* atau penyandian spesifik yang bertahan utuh melalui penerjemahan EBCDIC, taktik siluman ini kerap mengecoh Analis SOC muda yang memindai lalu lintas menggunakan alat deteksi *Regex* ASCII tradisional.

6.5 Db2 Database Injection (SQLi on Steroids)

Core Banking menyimpan saldo di pangkalan data relasional IBM Db2. Serangan Injeksi SQL pada aplikasi Web perbankan modern telah dimitigasi (*Prepared Statements*), tetapi **Stored Procedure Injection** di Db2 warisan sering diabaikan.

Dengan mengeksploitasi *Stored Procedures* COBOL/Java di Db2 yang mengkompilasi *Dynamic SQL* dari *Input Client*, peretas memutus rantai keamanan transaksi finansial. Mereka merangkai (*Chain*) injeksi untuk membaca tabel sistem (`SYSIBM.SYSTABLES`) dan membongkar struktur kerangka pembukuan uang (*Financial Ledger Schema*) bank secara diam-diam.



BAGIAN VII

Adversarial AI & Quantum Threats
(Ancaman Siber Generasi Selanjutnya)

BAB 7: ANCAMAN ERA DEPAN (NEXT-GEN)

7.1 Adversarial AI dalam Keuangan

Ancaman Siber Sektor Finansial bergeser dari manipulasi kode menjadi manipulasi Model Matematika (**Adversarial Machine Learning**). Sistem Penilaian Kredit (Credit Scoring) dan Deteksi Penipuan (Fraud Engine) bank dijalankan oleh AI.

Sindikat Kriminal melancarkan *Evasion Attacks* (Serangan Penghindaran) dengan merancang paket Transaksi Finansial siluman secara algoritmik. Transaksi dikalkulasi sedemikian rupa agar skor probabilitas penipuannya (*Fraud Probability Score*) di mesin AI bank berada tepat 0.1% di bawah ambang batas (*Threshold*) alarm. Perampokan uang miliaran rupiah bocor perlahan tanpa pernah menyalakan sirene keamanan.

7.2 Deepfake Audio untuk Wire Transfers (Vishing)

Penyerangan keamanan informasi finansial tidak lagi berwujud injeksi basis data, melainkan **AI Audio Deepfake Vishing (Voice Phishing)**. Bank modern menggunakan verifikasi biometrik suara untuk memberikan otorisasi Transfer Dana *Wire Transfer* skala VVIP.

Menggunakan klon suara AI (Seperti *ElevenLabs* API) yang dilatih dari wawancara publik YouTube seorang CEO Korporasi, peretas menelpon *Manager Finance* (atau Call Center Bank VIP) dengan meniru mutlak nada dan gaya bicara CEO tersebut, secara meyakinkan memaksa pengiriman transfer uang *Off-Shore* senilai jutaan dolar dengan alasan "Akusisi Bisnis Rahasia".

7.3 Poisoning Fraud Detection Models

Serangan paling tersembunyi terhadap Bank bertenaga AI adalah **Data Poisoning (Meracuni Dataset Pelatihan)**. Daripada menyerang aplikasi *Mobile Banking* yang dijaga ketat, peretas menyusup ke *S3 Bucket Storage* Bank tempat data historis Nasabah disiapkan untuk *Training Model ML* esok harinya.

Peretas menyuntikkan (Inject) ribuan baris rekaman Transaksi Kartu Kredit Curang milik mereka sendiri dan melabelinya sebagai `VALID_TRANSACTION = TRUE`. Ketika Bank melatih ulang (*Retrain*) Model AI *Anti-Fraud*-nya, Model secara permanen buta (Amnesia) terhadap taktik kriminal grup peretas tersebut. Pertahanan Sistem runtuh dari dalam logikanya sendiri.

7.4 Quantum Threat (Q-Day) terhadap Finansial

100% dari Enkripsi Otentikasi HTTPS Perbankan, Verifikasi PIN ATM, dan Kunci VPN SWIFT hari ini mengandalkan RSA atau *Elliptic Curve* (ECC). **Ancaman Kuantum (Shor's Algorithm)** secara matematis akan mendekripsi semua kunci ini dalam hitungan menit di masa depan (Q-Day).

Ancaman HNDL (Harvest Now, Decrypt Later) berarti lalu lintas transaksi finansial rahasia hari ini sedang disadap dan disimpan oleh agensi musuh. Arsitek Enterprise Bank wajib memigrasikan saluran *Routing* Kritis mereka ke Standar Kriptografi Pasca-Kuantum (*PQC/ML-KEM*) hari ini, memastikan keamanan data perbankan terlindungi secara retroaktif sebelum Komputer Kuantum komersial pertama menyala.

REFERENSI JURNAL & STANDAR KRITIS

- **[1]** SWIFT. (2025). *Customer Security Controls Framework (CSCF) v2025*.
- **[2]** CISA & FBI. (2020). *Cybersecurity Advisory: FASTCash 2.0: North Korea's BeagleBoyz Robbing Banks*.
- **[3]** Paxson, V. (1999). *Bro: A System for Detecting Network Intruders in Real-Time*.
- **[4]** Roth, F., & Patzke, C. (2017). *Sigma: Generic Signature Format for SIEM Systems*.
- **[5]** Microsoft Corp. (2022). *Use Windows Event Forwarding to Help with Intrusion Detection*.

GLOSARIUM KEAMANAN FINANSIAL (A-M)

TERMINOLOGI	DEFINISI & KONTEKS TELEMETRI SIEM
Golden Ticket	Tiket otentikasi (Kerberos TGT) yang dipalsukan secara mandiri oleh Hacker menggunakan Kunci KRBTGT curian. Memungkinkan hak akses Super-Admin Windows AD tak terbatas. Deteksi memburu Anomali TGT Lifecycle (Event ID 4769).
ISO 8583	Standar internasional format pesan sistem transaksi finansial (Kartu Kredit/ATM). Berbasis *Bitmap* Data Element. Dianggap rentan secara bawaan karena ketiadaan Enkripsi Payload tingkat dasar. Target pencegatan *Man-in-the-Middle* APT finansial.
Lateral Movement	Teknik peretas (Setelah menjebol 1 PC Cabang) merayap berpindah menyusupi Server-server Pusat Data menggunakan kredensial sah. Memburu anomali ini butuh korelasi NetFlow/Zeek East-West.

GLOSARIUM KEAMANAN FINANSIAL (N-Z)

TERMINOLOGI	DEFINISI & KONTEKS TELEMETRI SIEM
SOAR	*Security Orchestration, Automation, and Response*. Robot perangkat lunak *Python* SOC yang membaca Peringatan SIEM, lalu secara otomatis mengeksekusi aksi Karantina ke Firewall/Switch (Machine-Speed Defense Zero-Downtime).
SWIFT MT/MX	Format pengkodean tekstual berpemilik untuk merutekan instruksi pergerakan Uang Kliring antar Bank Sentral Dunia. Memantau Integritas Pesan ini adalah jantung *Threat Hunting* Perbankan.
Zero-Downtime Containment	Strategi Isolasi Infeksi Jaringan (via SDN Firewall Hypervisor) yang hanya memblokir *Port* Kendali Outbound, sambil Membiarkan *Port Bisnis Database* tetap Hidup, menekan kerugian finansial SLA Bank Nasional menjadi Nol Rupiah.



The Financial Cyber Architect

© 2026 All rights reserved.
Enterprise Financial Threat Hunting Series